

OMAR A. VARDI
CYSE 270: Linux System for Cybersecurity
Assignment 3
Total: 100 Points

Instructions

1. Perform every task on your Linux system using the appropriate commands.
2. Include screenshots showing each command and its output.
3. Provide written answers to all analyst questions.
4. Combine your screenshots and written responses into a single Word or PDF file.
5. Clearly label every response and screenshot with its corresponding step number.
6. You may use one screenshot for multiple related steps if the commands and outputs are clearly visible.
7. Commands must be typed and visible in your screenshots. Screenshots containing only output will not receive full credit.
8. Your results may differ from those of your classmates because systems can contain different user accounts.

Operation Ghost Account

Role: Junior Cybersecurity Analyst

Mission time: 45-60 minutes

Incident Brief

Your organization's monitoring system detected suspicious account activity on a Linux server. An attacker may have created an account or accessed an existing one.

Your task is to examine `/etc/passwd`, identify accounts that deserve further investigation, and submit a short analyst report.

Important: Finding an account does not prove it is malicious. Cybersecurity professionals collect evidence before reaching conclusions.

Mission 1: Initial Reconnaissance (20 points)

1. Inspect the beginning of the account database

- - Display the first five entries in /etc/passwd.

```
(kali㉿kali)-[~]  
$ cat /etc/passwd | head -5  
root:x:0:0:root:/root:/usr/bin/zsh  
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin  
bin:x:2:2:bin:/bin:/usr/sbin/nologin  
sys:x:3:3:sys:/dev:/usr/sbin/nologin  
sync:x:4:65534:sync:/bin:/bin/sync
```

- **Analyst note: Which account appears first?**
 - Root account or the “/usr/bin/zsh”
- **Why is this account important on a Linux system?**
 - This is where the root account lies, where permissions are elevated, and you get admin privileges. Also, this is where the zshell “zsh” is too, where it contains some of the important commands

2. Inspect the newest-looking entries

Account entries are often added near the end of /etc/passwd.

- **Display the last five entries.**

```
Session Actions Edit View Help  
(kali㉿kali)-[~]  
$ cat /etc/passwd | tail -5  
mosquitto:x:970:970::/var/lib/mosquitto:/usr/sbin/nologin  
inetsim:x:116:116::/var/lib/inetsim:/usr/sbin/nologin  
mysql:x:969:969:MariaDB Server:/nonexistent:/bin/false  
_gvm:x:117:117::/var/lib/openvas:/usr/sbin/nologin  
kali:x:1000:1000::/home/kali:/usr/bin/zsh
```

- **List two usernames that appear:**
 - Kali
 - mysql
- **Do these appear to be human accounts, service accounts, or are you unsure?**

- From the looks of it, there are multiple service accounts and one user account. Kali is our user account, and mysql is a service account used by MySQL, and the rest are service accounts, I think.

3. Examine a specific evidence window

- Display entries 6 through 10 using both head and tail.

```
(kali㉿kali)-[~]  
$ cat /etc/passwd | head -10 | tail -5  
games:x:5:60:games:/usr/games:/usr/sbin/nologin  
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin  
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin  
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin  
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
```

- Explain how this pipeline isolates lines 6–10:
 - “Head -10” outputs the first 10 lines of the file, and then piping the “tail -5” produces the last 5 lines of that head command, producing the output of 6-10 lines.

Mission 2: Hunt for High-Value Accounts (20 points)

4. Locate the root account

- Search for a line beginning with root:.

```
Session Actions Edit View Help  
(kali㉿kali)-[~]  
$ cat /etc/passwd | grep '^root'  
root:x:0:0:root:/root:/usr/bin/zsh
```

- Why is the root account particularly valuable to an attacker?
 - The root account has escalated admin privileges. If an attacker can gain access to root, they can do almost anything without the system questioning them.

5. Identify accounts with an interactive shell

- - Find account entries that end with /bin/bash.

```

Session Actions Edit View Help
(kali㉿kali)-[~]
$ cat /etc/passwd | grep '/bin/bash$'
postgres:x:115:115:PostgreSQL administrator:/var/lib/postgresql:/bin/bash

```

- How many accounts use /bin/bash?
 - In my VM only one account uses “/bin/bash,” and that is the postgres account.
- Why might an analyst examine accounts with interactive shells?
 - Interactive shells matter because they let users log in and run commands. Just imagine if a bad actor ssh through one of the interactive shell accounts they can quietly execute commands without you knowing unless you know what to find and examine for.

Mission 3: Investigate Service Accounts (15 points)

6. Find accounts that cannot normally log in interactively

- Search for accounts containing nologin.

```

(kali㉿kali)-[~]
$ cat /etc/passwd | grep -n 'nologin'
2:daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
3:bin:x:2:2:bin:/bin:/usr/sbin/nologin
4:sys:x:3:3:sys:/dev:/usr/sbin/nologin
6:games:x:5:60:games:/usr/games:/usr/sbin/nologin
7:man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
8:lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
9:mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
10:news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
11:uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin

```

- How many matching accounts did you find?

```

(kali㉿kali)-[~]
$ cat /etc/passwd | grep -c 'nologin'
49

```

- Does nologin automatically mean the account is suspicious?
 - No
- Explain your answer:
 - Upon inspection of the output, it seems like the ‘/usr/bin/nologin/’ service and user accounts are prevented from logging in interactively. Or they may be intentionally prevented from interactive login, which isn't suspicious. I see it more as a VM security rule than a red flag.

7. Record the locations of the evidence

- Display matching entries with their line numbers.
 - `grep -n "nologin" /etc/passwd`

```
(kali㉿kali)-[~]  
└─$ grep -n "nologin" /etc/passwd  
2:daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin  
3:bin:x:2:2:bin:/bin:/usr/sbin/nologin  
4:sys:x:3:3:sys:/dev:/usr/sbin/nologin  
6:games:x:5:60:games:/usr/games:/usr/sbin/nologin  
7:man:x:6:12:man:/var/cache/man:/usr/sbin/nologin  
8:lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin  
9:mail:x:8:8:mail:/var/mail:/usr/sbin/nologin  
10:news:x:9:9:news:/var/spool/news:/usr/sbin/nologin  
11:uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin  
12:proxy:x:13:13:proxy:/bin:/usr/sbin/nologin  
13:www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin  
14:backup:x:34:34:backup:/var/backups:/usr/sbin/nologin  
15:list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin  
16:irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
```

- How could line numbers help an analyst document evidence?
 - The only thing I can think of is better documentation for a report. If another coworker reads my report, they can precisely refer to that exact entry or line.

Mission 4: Use Regular Expressions to Narrow the Hunt (20 points)

8. Search for two specific accounts

- Determine whether the system contains either the root or nobody account.

```
Session Actions Edit View Help  
(kali㉿kali)-[~]  
└─$ cat /etc/passwd | grep -E 'root|nobody'  
root:x:0:0:root:/root:/usr/bin/zsh  
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin  
nm-openvpn:x:981:981:NetworkManager OpenVPN:/var/lib/openvpn/chroot:/usr/sbin/nologin
```

- Which accounts were found?
 - Root and nobody accounts
- What does `|` mean in this regular expression?
 - It means either/or and requires the -E option when used with grep.

9. Search by username pattern

- Find usernames beginning with a, b, or c.

```
Session Actions Edit View Help
(kali@kali)-[~]
$ cat /etc/passwd | grep -E '^[a|b|c]'
bin:x:2:2:bin:/bin:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
avahi:x:103:104:Avahi mDNS daemon:/run/avahi-daemon:/usr/sbin/nologin
colord:x:975:975:colord colour management daemon:/var/lib/colord:/usr/sbin/nologin
cups-pk-helper:x:109:999:user for cups-pk-helper service:/nonexistent:/usr/sbin/nologin
```

- Record up to three matches:

```
(kali@kali)-[~]
$ cat /etc/passwd | grep -E '^[a|b|c]' | head -3
bin:x:2:2:bin:/bin:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
avahi:x:103:104:Avahi mDNS daemon:/run/avahi-daemon:/usr/sbin/nologin
```

10. Hunt for usernames containing numbers

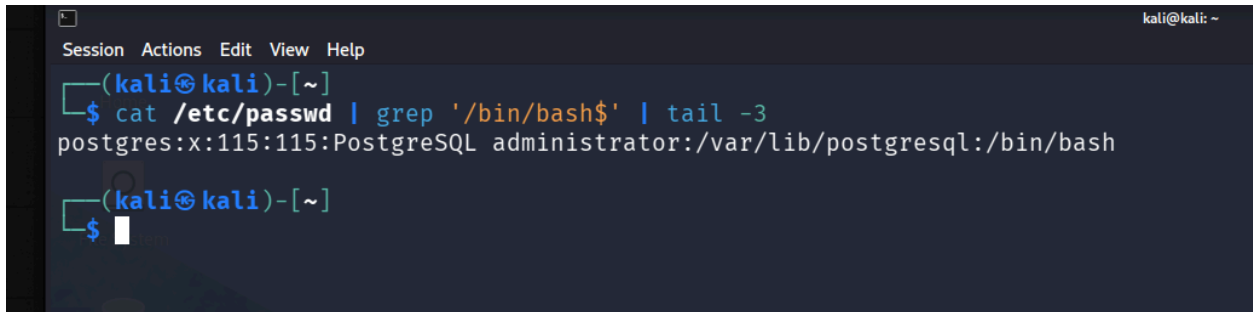
- Attackers sometimes create usernames that resemble legitimate accounts, such as admin1 or support2. Find usernames containing at least one digit.

grep -E "^[^:]*[0-9][^:]*:" /etc/passwd

- Were any accounts found?
 - No
- If yes, record them:
 - N/A
- Does a number in a username prove that the account is malicious?
 - No
- What additional evidence would you need?
 - Figuring out if the account was used for suspicious activity. So we look into the account creation history, command history, logging in activities.

Final Challenge: Produce an Evidence Summary (15 points)

- The incident-response lead wants the last three accounts that have access to /bin/bash.
- Write and run one command that produces this evidence:



```
Session Actions Edit View Help
(kali㉿kali)-[~]
$ cat /etc/passwd | grep '/bin/bash$' | tail -3
postgres:x:115:115:PostgreSQL administrator:/var/lib/postgresql:/bin/bash
(kali㉿kali)-[~]
$
```

- Record the results:
 1. Postgres account

Command-order investigation

- Now reverse the order:
- Did the two commands produce the same results?
 - No
- Explain why changing the command order changed, or did not change, the results:
 - Linux bash reads commands from left to right. The “tail” command needs an input to be piped on so it can produce its output. Doing “tail” command first negates its purpose of displaying the last lines of a file.

Submit Your Analyst Verdict (10 points)

- Based only on this investigation, did you find definitive evidence of a compromised account?
 - No
- Identify one account you would investigate further and explain why:
 - It could be the postgres account or in general any account that ends with “/bin/bash” the reason it is an interactive shell where attackers can get into and revise or create interactive commands. On top of that they can SSH and execute commands which is a big no no.

